LATTICE NETWORK

Whitepaper Tecnico

Infrastruttura sovrana di comunicazione aziendale
post-quantistica · auto-ospitata · senza dipendenze terze

Versione	1.0
Data	Giugno 2026
Algoritmo firma	ML-DSA-65 · NIST FIPS 204
Consenso	QBFT · 2f+1
Licenza core	BSL 1.1 → Apache 2.0

INDICE

Sommario

1. 1. Sintesi
2. 2. Crittografia
3. 3. Consenso
4. 4. Privacy del traffico (Mixnet)
5. 5. Anti-abuso (ZK-RLN)
6. 6. Recupero chiavi (2-di-3 Shamir)
7. 7. Architettura del deployment
8. 8. Audit e verificabilità
9. 9. Modello di licenza
10. 10. Limiti dichiarati
11. 11. Confronto con alternative
12. 12. Stato del software

1. Sintesi

Lattice Network è un'infrastruttura di comunicazione aziendale on-premise che combina firme post-quantistiche, una blockchain proof-of-authority senza token, e cifratura end-to-end. Non sostituisce strumenti esistenti come la PEC: ne fornisce un'alternativa sovrana, auto-ospitata dal cliente, senza dipendenza da fornitori terzi (no SMTP esterno, no chiavi gestite in cloud, no telemetria).

Il prodotto è composto da tre moduli funzionali:

- **LNS** — Lattice Name Service: identità digitale per ogni dipendente

(chiave ML-DSA-65, X25519 per cifratura, fingerprint pubblico).

- **Pulse** — messaggistica interna stile chat, end-to-end cifrata.
- **Certify** — sostituto della PEC tradizionale: mail notarizzata

on-chain con ricevuta crittografica firmata dal destinatario.

Tutti gli artefatti crittografici sono verificabili pubblicamente sulla blockchain interna. Il server non vede mai il contenuto di messaggi o mail.

2. Crittografia

2.1 Firme

Tutte le firme della rete usano **ML-DSA-65** (NIST FIPS 204), il primo schema di firma post-quantistico standardizzato (agosto 2024). Parametri:

Chiave pubblica	1.952 byte
Chiave privata	4.032 byte (formato esteso)
Firma	3.309 byte
Sicurezza	NIST Level 3 (~AES-192)

L'implementazione client-side gira interamente nel browser dell'utente tramite un modulo WebAssembly compilato da Rust (`ml-dsa` crate del gruppo RustCrypto). Il server riceve solo la chiave pubblica e le firme prodotte — la chiave privata non lascia mai il dispositivo dell'utente.

2.2 Cifratura

- **At-rest** (database MongoDB): AES-256-GCM con envelope encryption

(master key separata per ambiente, AAD legata all'ID del record).

- **In-transit** (TLS): demandato al reverse proxy (Cloudflare Tunnel o

nginx).

- **End-to-end** (Certify e Pulse): X25519 ECDH per derivare una chiave

effimera, AES-256-GCM per la cifratura del contenuto. Il server vede solo ciphertext.

2.3 Funzioni hash

• **SHA3-512** (NIST FIPS 202) per i digest dei documenti notarizzati

e l'hash chain del registro di audit.

• **SHA3-256** per i fingerprint delle chiavi e gli identificatori di

share Shamir.

• **Poseidon** (variante Starknet, p ≈ 2²■¹) per i commitment dello

schema ZK-RLN.

3. Consenso

Il livello di consenso usa **QBFT** (Quorum Byzantine Fault Tolerance), una variante PBFT senza token nativo. La rete di base prevede 4 validatori indipendenti; un blocco viene finalizzato solo dopo aver raccolto 2f+1 = 3 firme ML-DSA-65 da processi distinti.

Ogni blocco contiene:

- indice progressivo;
- timestamp UTC;
- hash del blocco precedente (SHA3-512);
- Merkle root delle transazioni (SHA3-512);
- lista delle firme ML-DSA-65 dei validatori partecipanti.

Le transazioni notarizzate sono di sette tipi: `IdentityRegister`, `IdentityRevoke`, `IdentityDelete`, `NotarySeal` (Certify), `DeliveryReceipt` (ricevuta PEC), `KeyShareEnroll`, `KeyShareRecover`. Ogni transazione contiene un `doc_hash` SHA3-512 del payload — **mai il payload in chiaro**.

4. Privacy del traffico (Mixnet)

Il livello Pulse usa un mixnet a tre hop di stile Loopix. Ogni messaggio viene cifrato in tre layer concentrici (ChaCha20-Poly1305), uno per ciascun relay; ogni relay decifra il proprio strato, applica un ritardo distribuito secondo Poisson, e inoltra al successivo. Il primo relay conosce il mittente ma non il destinatario; l'ultimo conosce il destinatario ma non il mittente; il relay intermedio non conosce nessuno dei due.

La configurazione di base esegue i tre relay su processi distinti dello stesso host. Per anonimato di rete reale è necessario eseguirli su infrastrutture in regioni geografiche differenti.

5. Anti-abuso (ZK-RLN)

Per impedire spam senza rivelare l'identità del mittente, Pulse usa

Rate-Limit Nullifiers (RLN) su curva BN254. Ogni messaggio include:

- un commitment Poseidon dell'identità (statico);
- un nullifier Poseidon(identity, epoch) (rotante ogni 60s);
- una prova a conoscenza zero di tipo Chaum-Pedersen (Fiat-Shamir) che

dimostra la conoscenza del secret senza rivelarlo.

Il backend rifiuta nullifier duplicati nella stessa epoca, applicando un limite di 10 messaggi/60s per identità. L'implementazione attuale usa un protocollo sigma su BN254 reale (libreria `py_ecc`); è prevista una sostituzione con Groth16 (arkworks) per ridurre la dimensione della prova.

6. Recupero chiavi (2-di-3 Shamir)

Lattice non offre "reset password": senza la propria chiave privata, un utente non può più accedere. Per gestire la perdita di chiave senza introdurre un'autorità di custodia, ogni utente può configurare un backup distribuito 2-di-3 tra colleghi nominati:

1. La chiave privata viene divisa via **Shamir Secret Sharing** su GF(256)

in tre frammenti, recuperabili da qualsiasi sottoinsieme di due. L'implementazione è in Rust, compilata in WebAssembly, eseguita nel browser del proprietario della chiave.

1. Ogni frammento viene sigillato con la chiave pubblica X25519 di un

nominato (ECIES, X25519 + AES-256-GCM).

1. Il server riceve solo i tre ciphertext opachi e i tre fingerprint

SHA3-256, notarizzati on-chain come transazione `KeyShareEnroll`.

1. In caso di recupero, due dei tre nominati decifrano localmente il

proprio frammento e lo re-sigillano per la nuova chiave pubblica del richiedente; il browser ricombina i due frammenti e ottiene la chiave originale. La transazione `KeyShareRecover` viene notarizzata on-chain.

In nessun punto del flusso il server vede la chiave privata in chiaro o i frammenti decifrati.

7. Architettura del deployment

Il deployment di base prevede una singola macchina che esegue:

- 1 processo backend FastAPI (porta 8001);
- 4 processi validatori QBFT (porte 9001-9004);
- 3 processi relay mixnet (porte 9101-9103);
- 1 istanza MongoDB con autenticazione;
- 1 sidecar di backup notturno (dump GPG AES-256, retention 30 giorni);
- 1 reverse proxy (Cloudflare Tunnel o nginx) per il TLS pubblico.

Tutti i componenti sono containerizzati. L'installazione richiede una VM con 2 vCPU, 4 GB RAM e 50 GB di storage; l'installer guidato (`installa.sh`) genera i secret, esegue il bootstrap del Platform Operator, e avvia lo stack in 10-15 minuti.

Per ambienti che richiedono una vera tolleranza ai guasti geografica, i 4 validatori e i 3 relay possono essere distribuiti su VM indipendenti in regioni differenti, connesse tramite una mesh WireGuard.

8. Audit e verificabilità

- Tutte le firme PQC sono verificabili tramite l'endpoint

`/api/ledger/verify/{tx_id}`, che ricostruisce il messaggio canonico e lo verifica con la chiave pubblica del firmatario.

• Il registro di audit interno è una hash chain SHA3-512 append-only;

`/api/audit/verify` rileva qualsiasi manomissione retroattiva.

• La pagina `/audit/{slug}` è pubblica e mostra senza login il numero

di transazioni firmate da un'azienda, l'altezza del blocco e gli hash delle ultime 10 transazioni — utile per la due diligence di controparti.

• Lo stato in tempo reale del consenso e dei relay mixnet è esposto da

`/api/qbft/alerts` (probe attivo dei processi, calcolo quorum 2f+1, generazione alert su state change).

9. Modello di licenza

• **Core crittografico** (`lattice-crypto`, `lattice-node`,

`pulse-protocol`, `lattice-zk-rln`, `lattice-mixnet`, `pulse-ratchet`): licenza BSL 1.1, audit pubblico, conversione automatica a Apache 2.0 dopo 4 anni.

• **Console di amministrazione** (`lattice-admin-console`,

`certify-gateway`, `lattice-py`, `lattice-wasm`): licenza commerciale proprietaria.

10. Limiti dichiarati

Il prodotto è progettato per **comunicazioni aziendali interne** e per sostituire la PEC nelle interazioni B2B. Non è progettato per:

• comunicazioni anonime contro avversari di livello statale (il mixnet

fornisce privacy del traffico solo se i relay sono distribuiti);

• conservazione a tempo indefinito (la retention dei backup è

configurabile dal cliente; il registro on-chain cresce linearmente con l'uso);

• sostituire l'autenticazione SPID/CIE quando richiesta per legge.

I limiti di throughput osservati nei test interni sono dell'ordine di ~300 mail Certify/minuto e ~600 messaggi Pulse/minuto per tenant, condizionati dal tempo di firma ML-DSA-65 (~2 ms per messaggio) e dal quorum QBFT (~400 ms per blocco). Numeri superiori richiedono sharding del tenant o backend in cluster.

11. Confronto con alternative

Caratteristica	PEC tradizionale	Email + S/MIME	Lattice Certify
Server di fiducia	Provider PEC	Provider mail	Nessuno (self-hosted)
Cifratura end-to-end	No	Sì (con S/MIME)	Sì (X25519 + AES-GCM)
Firma post-quantistica	No (RSA/EC)	No (RSA/EC)	Sì (ML-DSA-65)
Notarizzazione on-chain	No	No	Sì (QBFT 2f+1)
Recupero chiave	Provider	Manuale	2-di-3 nominati
Costo per messaggio	~0,30 €	Variabile	Zero (auto-ospitato)

Lattice non è un sostituto legale della PEC per le comunicazioni dove la legge italiana richiede esplicitamente la PEC (es. notifiche giudiziarie); fornisce però una garanzia crittografica più forte per le comunicazioni B2B dove i contraenti accettano lo strumento.

12. Stato del software

Tutti i componenti elencati in questo whitepaper sono implementati e funzionanti. Il sistema è stato sottoposto a una suite di test automatici (84 test pytest attivi al momento della redazione, 100% pass rate). Non è ancora stato sottoposto a un audit di sicurezza esterno indipendente, che è raccomandato prima della messa in produzione multi-tenant pubblica.

Il codice sorgente del core BSL è ispezionabile dai clienti come parte del processo di acquisto. La verifica fattuale delle proprietà crittografiche descritte (algoritmi standardizzati, librerie pubbliche, nessuna chiave nelle mani del fornitore) è alla portata di qualsiasi revisore tecnico in ~1 giorno-uomo.

Contatti: enterprise@lattice.id

Questo documento è un'analisi tecnica neutra. Non costituisce promessa di certificazione, conformità normativa o garanzia di assenza di vulnerabilità. Si raccomanda un audit indipendente prima della messa in produzione.